

Such hash chains have a few problems though. They suffer from the defects of merging chains and cyclical chains. If we happen to start with a plaintext which at some point in the chain results in a plaintext / hash included in another chain, then after that point, the chains will “merge” and produce the same result. This causes inefficiencies in storage. A cyclical chain will result when a hash along the chain results in the plaintext we started the chain with.

Rainbow tables counter such defects.

In a rainbow table, the reduction function used is varied across the iterations. This makes looking up hashes more complicated, as they need to be tested with each reduction function, but the chances of branches merging are negligible and cyclical chains are not formed.

Now that we know how rainbow tables work. Let us look at the way to counter them Salts.

A salt is just a randomly generated non-secret sequence that is added to the password to make it truly unique. This way even for two users with the same password, the hashes will be different. If we add a simple single character salt to the original plaintext, we get a drastically different hash.

If a hacker is prepared with rainbow tables up to 7 alphanumeric characters, the addition of a salt of a single character to the 7 will make the rainbow tables useless. Of course, hackers can be better prepared in the future and have rainbow tables pre-computed for all possible salt values provided the salt is small enough.

Older UNIX passwords were stored with a 12-bit hash that meant that the passwords could be cracked if the hacker was prepared with a table for each of the 4096 possible salt values. With hard drive prices getting cheaper, hackers were able to create tables for all salt values and store them, making it possible to crack such passwords.

A rainbow table for a MD5 hash for lowercase-alpha-numeric passwords is around 3GB in size. For a 12-bit salt, this would jump the size to 12TB! This could perhaps be compressed to around 4TB; such storage capacities are available nowadays.

However a simple increment of 2-bits for the salt, and we will need 4 times as much space. So if a salt of 48 bits to 128 bits is used – as it is in current *nix OSs – the hash becomes impractical to crack.

2.2.3 Cracking a hash with rainbowcrack

The first step is to generate the rainbow tables, which is done using the utility “rtgen”. We need to provide some configuration options such as the hashing algorithm the character set, the password lengths, etc.